

BENEFITS

AUDIT PROGRAM #40-00-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
March 2026	Planning	Self-Service report	Michelle Galiza	Added items that can be considered for self-service execution.
December 2025	Planning Vendor Management	Self-Service Report VM001.P, VM002.P, VM003.P	Michelle Galiza	Updated OpenPages report exporting and vendor management testing
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes to audit risk levels from recent revalidation
December 2024	Planning	Reference Material, Self-Service Report and Fraud Template	Jessica Lin	Updated links of Corporate Directives and added Self-Service Report
April 2023	Data Protection	OT003.P	Don Dobrzelewski	Updated Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

BENEFITS

AUDIT PROGRAM #40-00-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	5
PLANNING: Data Analysis.....	6
PLANNING: Reference Material	9
PLANNING: Self-Service Report	10
PLANNING: Fraud Template.....	10
CONTROL ASSESSMENT QUESTIONS	11
Key Control Question: 1. Benefits (Medical and Ancillary).....	11
Primary Test: Eligibility Determination and Validation (BN001.P).....	12
Primary Test: Contribution Collection and Remittance (BN002.P)	13
Primary Test: Claims Processing (BN003.P)	14
Primary Test: Benefits Funding (BN004.P)	15
Primary Test: Reserves (BN005.P).....	17
Key Control Question: 2. Other Tests: Use for All Aspects of HR Primary and Business Processes	18
Primary Test: Acquired Employees - Post Integration (OT001.P)	18
Primary Test: Compliance with Laws and Regulations (OT002.P)	20
Primary Test: Data Protection (OT003.P).....	21
Key Control Question: 3. Vendor Management.....	23
Primary Test: Contract Management (initial contract as well as contract changes) (VM001.P).....	24
Primary Test: Contract Performance Measurements (VM002.P)	25
Primary Test: Vendor Cost (VM003.P)	26

BENEFITS

AUDIT PROGRAM #40-00-00

PROCESS AND OBJECTIVE

Process Definition:

The Benefits process encompasses programs such as health (medical, dental, prescription drug, vision, mental health), other forms of insurance (disability, life, accident), and other benefits as applicable by country (excluding pension, which is covered under the Pension Benefit Management process). Active and retired employees - and their dependents - may be eligible for these benefits.

In many countries, IBM employees fund some of the benefits program costs through their own contributions (in addition to the funding provided by IBM).

In general, health benefits and life insurance are the most significant benefit programs in terms of costs and potential risks to IBM. However, the risks differ depending on whether these programs are self-insured or fully insured (see the Terminology section below).

Process Objective:

The objective of the Benefits process is to offer and manage programs that contribute, as part of the overall employee-total compensation package, in attaining IBM's objectives of attracting and retaining the most highly capable employees in support of IBM's business goals

Process Terminology:

Program Administrators (PAs)

The execution of the Benefits process is normally handled by benefits program administrators (PAs), who can be either IBM employees, contractors, or vendors. There are three typical program execution arrangements:

- An IBM employee or contractor is the PA, and there are no vendors. This normally applies only to small programs.
- An IBM employee or contractor provides eligible participant data to the vendor PA, who administers benefit claims for benefits participants on IBM's behalf. IBM monitors the vendor PA to ensure benefits are being properly administered.
- An IBM employee or contractor provides eligible participant data to a third-party broker, who then communicates this information to the vendor PA. The third-party broker is responsible for managing the process with the vendor PA and reports the results to IBM.

In all cases, IBM has the overall responsibility for ensuring that eligibility data is correctly processed and reconciled between all relevant parties and that benefits programs are being properly administered and funded.

Self-Insured (SI) vs. Fully Insured (FI) Plans

For insured benefit plans, there are two main types of plans: self-insured and fully insured. The program risks are different between these two types.

In self-insured plans, IBM provides the funding to the PA, who pays the claims, while IBM continues to bear the full financial risk. For these plans, claims processing needs to be tested, since IBM bears the risk. (Note: In some countries, detailed claims information cannot be tested due to local privacy legislation.)

For benefit plans that are fully insured, claims testing is not relevant. In these plans, IBM remits premiums to the PA, who pays the claims from the premium funding and bears the financial risk for those claims.

BENEFITS

AUDIT PROGRAM #40-00-00

PROCESS AND OBJECTIVE (Continued)

For both plan types, IBM generally pays an administration fee to the PA in addition to the funding for claims or premiums.

Process Control Assessment Objectives:

- Ensure participant eligibility for benefits was properly assessed and verified before benefits claims were paid.
- Ensure employee contributions (where applicable) were correctly withheld (collected) from employees.
- Ensure both employee and IBM contributions were correctly remitted to vendors for the payment of premiums and/or administration fees.
- For self-insured plans, ensure benefits claims were promptly and correctly processed for eligible participants.
- Ensure contributions and premiums or claims paid were correctly recorded on IBM's ledger (US only).
- Ensure adequate funding was available when required, was reconciled, and any adjustments were correct, supported, and properly approved before ledger entries were made (US only).
- For benefit services that have been outsourced to a vendor, ensure IBM's interests were adequately protected through appropriate vendor management.
- Ensure process design and execution protect personal information (PI) and sensitive personal information (SPI) for active and retired employees and their dependents who are eligible for benefit programs.
- Ensure the benefits process complied with applicable laws and regulations, including any country-specific requirements.

BENEFITS

AUDIT PROGRAM #40-00-00

PLANNING: Audit Program Risk Alignment

Benefits

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Vendor Management	High	Contract management (initial contract as well as contract changes)	VM001.P
		Contract performance measurements – service level agreements (SLAs) and/or key performance indicators (KPIs)	VM002.P
		Vendor invoice validation and payment	VM003.P
Eligibility Determination and Validation	Medium	Benefits (Medical and Ancillary)	BN001.P, OT001.P
Contribution Collection and Remittance	Medium	Benefits (Medical and Ancillary)	BN002.P
Claims Processing	Medium	Benefits (Medical and Ancillary)	BN003.P
Data Privacy	Medium	Other Tests: Use for All Aspects of HR Primary and Business Processes	OT002.P, OT003.P
Benefits Funding and Reserves	Low	Benefits (Medical and Ancillary)	BN004.P, BN005.P

BENEFITS

AUDIT PROGRAM #40-00-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Universe of Eligible Employees	- Determine whether newly eligible participant records (e.g., new enrollments) were correctly sent to the PA - Determine whether participant status changes affecting eligibility were correctly sent to the PA. - Determine whether a reconciliation was performed ensuring that the total eligibility records-sent to the PA matched with what was received by the PA	- Eligible participants missed - Ineligible participants added or not removed (e.g., during separations)	Failure to properly determine and confirm that individuals submitting claims are eligible to receive benefits could result in excess expenditures, rejection of valid claims, employee dissatisfaction, and legal disputes, or fraudulent activities.

BENEFITS

AUDIT PROGRAM #40-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Universe of Claims received and processed (for self-insured plans)	- Determine whether claims were promptly and correctly processed for eligible employees. - Review if there is an effective process to detect and minimize overpayment.	- Claims processed for ineligible services. - Invalid or suspect claim amounts. - There may be a clip level for dollar value to be reviewed for claims; therefore, inaccurate amounts less than the clip level might not be detected. - Overpayments not recovered and credited to IBM. - Aging claims not being managed to closure. - Appeal process for denied claims not followed.	Failure to promptly and correctly pay valid claims made by eligible participants could result in excess expenditures, employee dissatisfaction, disputes, and risk of litigation.
Employee Contributions / Payments (where applicable)	Determine whether employee contributions or payments (e.g., lease payments for cars) were correctly withheld for eligible employees and/or their dependents.	- Inaccurate or missing contributions/ payments. - Amounts not adjusted because of status / dependent changes.	Failure to promptly and correctly collect contributions could result in delays making funds available to pay premiums, fees, or claims, disputes over employee coverage, and risk of litigation.
Vendor Contract	- Review the terms of the contract regarding required vendor reporting, service level agreements (SLAs), and/or performance guarantees (if applicable). - Determine how the Benefits team is assured that the vendor is performing in accordance with contract requirements	- Required vendor reports not provided or SLA terms not met. - Performance guarantees not validated resulting in payment delays. - Insufficient monitoring of vendor activities.	Failure to properly manage relationships with vendors could result in excess expenditures, delayed or reduced quality of services, disputes, potential litigation, disrupted operations, employee dissatisfaction, and could enable fraudulent activities.
Vendor Premiums / Fees	Trending analysis of premium or fee amounts	Duplicate premiums / fees or noticeable premium or fee increases or decreases	Agreed-to contract terms may have been violated

BENEFITS AUDIT PROGRAM #40-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Benefits Funding	Determine whether adequate funding was available when required, was reconciled, and any adjustments were correct, supported, and ledger entries were approved and posted accurately	- Insufficient reconciliation process - No management visibility for adjustments or variances	Failure to assure adequate funding to pay claims made by eligible employees could result in disenrollment from benefit programs, employee dissatisfaction, disputes, incorrect or inadequate trust fund balances.
Data Access Reports Management and Data Privacy	- Select risk-based samples of transferred or separated employees that had access to Benefits database and functional IDs during the audit period; Validate if accesses were approved and removed in a timely fashion. - Validate that adequate controls are in place for transmission of PI/SPI data to third party.	Employees retaining access when not required.	Failure to protect PI and SPI could enable fraudulent activity, which could result in dissatisfied employees, damage to employees and to IBM's image, and expose IBM to risk of litigation. Inadequate access management, processing, transmission, and retention of PI/SPI could lead to unauthorized access and use of PI/SPI. This could further lead to legal implication for IBM and satisfaction

BENEFITS

AUDIT PROGRAM #40-00-00

PLANNING: Reference Material

IBM Corporate Directives - these can change over time

Corporate Policies

- 130: IBM Data Privacy Policy <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-130>

Corporate Instructions

Information Technology Security

- ITS 101: Information Technology Security Policy <https://w3.ibm.com/ibm/corporate-documents/its/its101>
- IT Security Standards (ITSS) <https://pages.github.ibm.com/ciso-psg/main/standards/itss.html>

Finance

- FIN 101: Control of Disbursements <https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>
- FIN 151: Application Systems Control and Auditability (ASCA) <https://w3.ibm.com/ibm/corporate-documents/fin/fin-151>
- FIN 182: Management Self-Assessment of Control <https://w3.ibm.com/ibm/corporate-documents/fin/fin-182>

Procurement

- PROC 167: Vendor Sourced Goods and Services <https://w3.ibm.com/ibm/corporate-documents/proc/proc-167>

Legal

- LEG 116: Classification and Control of IBM Information <https://w3.ibm.com/ibm/corporate-documents/leg/leg-116>
- LEG 117: Internet Privacy - Personal Information Collected On-Line <https://w3.ibm.com/ibm/corporate-documents/leg/leg-117>

Human Resources

- HR 113: Protection of Employee Information <https://w3.ibm.com/ibm/corporate-documents/hr/hr-113>

Process Documents, Applicable Laws and Regulations

- Global Process Owner's process requirements, documentation, and guidance
- Process requirements at a region, country, or local level
- Laws and regulations addressing topics such as data privacy, funding, aged claims, denied claims appeals, and taxability.
- General Data Protection Regulation (GDPR) Readiness: <https://www.ibm.com/data-responsibility/gdpr/#4>
- Data Privacy/Protection, Regulations, and Compliance: <https://w3.ibm.com/w3publisher/dprc>

BENEFITS AUDIT PROGRAM #40-00-00

PLANNING: Self-Service Report

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional materials to download information
- Management Self-Assessment of Controls (MSAC) - Risk Evaluations (RE's) - Proactive Business Control Reviews - All other reviews (local reviews, peer reviews, PricewaterhouseCoopers reviews) documented in FBC OpenPages	Exporting Reports from FBC OpenPages: 1. Log in to OpenPages. 2. Switch user profile to "FBC General User." 3. On the home page, navigate to the Reports section. 4. Select and export the required report(s) using the applicable filter criteria (e.g., date range, process type, status).

Note: Review the reports requested in the IDR and identify items that can be extracted directly from available systems or tools (e.g., lists of purchase orders, invoices, and similar records).

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Claims for services not rendered or for ineligible services or participants.	Verification of participant eligibility with program records	Chose a risk-based sample and ensure that the participants are eligible and at what level or program they are covered
Inadequate reconciliation of reimbursements for claims paid by vendor (for self-insured plans).	Review control points in the process for reconciliation of payments	Review the payments and the claims to ensure that the claims are valid and that they are not being double paid.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Benefits (Medical and Ancillary)

Objective:

Process Definition:

The Benefits process encompasses programs such as health (medical, dental, prescription drug, vision, mental health), other forms of insurance (disability, life, accident), and other benefits as applicable by country (excluding pension, which is covered under the Pension Benefit Management process). Active and retired employees - and their dependents - may be eligible for these benefits.

In many countries, IBM employees fund some of the benefits program costs through their own contributions (in addition to the funding provided by IBM).

In general, health benefits and life insurance are the most significant benefit programs in terms of costs and potential risks to IBM. However, the risks differ depending on whether these programs are self-insured or fully insured.

Process Objective:

The objective of the Benefits process is to offer and manage programs that contribute, as part of the overall employee-total compensation package, in attaining IBM's objectives of attracting and retaining the most highly capable employees in support of IBM's business goals

Control Assessment Topics

Eligibility: Determine participant eligibility for benefits was properly assessed and verified before benefits claims were paid.

Contribution Collection and Remittance: Determine whether employee contributions (where applicable) were correctly withheld (collected) from employees. Determine whether both employee and IBM contributions were correctly remitted to vendors for the payment of premiums and/or administration fees.

Claims processing (for self-insured plans): Determine whether benefits claims were promptly and correctly processed for eligible participants.

Benefits Funding and Reserves (US only): Determine whether contributions and premiums or claims paid were correctly recorded on IBM's ledger. Determine whether adequate funding was available when required, was reconciled, and any adjustments were correct, supported, and properly approved before ledger entries were made.

Risk/Exposure:

See risks noted in each test.

BENEFITS AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Benefits (Medical and Ancillary)

Primary Test: Eligibility Determination and Validation (BN001.P)

Risk:

Determine whether participant eligibility for benefits was properly assessed and verified before benefits claims were paid.

Risk or Exposure: Failure to properly determine and confirm that individuals submitting claims are eligible to receive benefits could result in excess expenditures, rejection of valid claims, employee dissatisfaction, legal disputes, or fraudulent activities.

Approach:

- Cross-check the list of participants in the benefit program with the list of participants provided to the Program Administrator (PA). Do the two lists reconcile? If there are discrepancies, can they be explained? Is the PA receiving information for all the participants who are enrolled in the benefit program? Is the PA (inappropriately) receiving information for employees who are not participants in the benefit program)?
- Review the participant eligibility rules for employees with different employment statuses (e.g., on a paid / unpaid leave of absence, recently separated). Request a list of employees who hold these statuses where they affect eligibility and compare it to the list of participants at the PA. Have status updates for these employees been properly communicated, to prevent payment of invalid claims (such as claims paid to former employees who may not be entitled to these payments)?
- Review the broader process for determining and verifying eligibility. How frequently are updated lists of eligible participants provided to the PA? Is the PA made aware of special circumstances that may affect eligibility? How are authorized retroactive changes handled when made by participants? How adequate and prompt is the process to incorporate retroactive changes participants can make to their benefits (for example, a qualified status change such as marriage or a new child)?

If spreadsheets or other soft copy means were used to transmit data, determine whether unauthorized changes that affect eligibility could be made without detection. Examples could include changes to date of eligibility, date of status change, and birthdate.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Benefits (Medical and Ancillary)

Primary Test: Contribution Collection and Remittance (BN002.P)

Objective:

Determine whether employee contributions (where applicable) were correctly withheld (collected) from employees. Determine whether both employee and IBM contributions were correctly remitted to vendors for the payment of premiums and/or administration fees. (Note: Payment of claims for self-insured plans is addressed separately, in test BN003.P.)

Risk or Exposure: Failure to promptly and correctly collect contributions could result in delays making funds available to pay premiums fees, or claims, disputes over employee coverage, and risk of litigation. Failure to accurately remit contributions could result in excess expenditures.

Approach:

- For any employee contributions, review the process for ensuring accurate contributions. Determine whether contributions were correctly paid for eligible participants and/or their dependents.
- Identify how changes to employee contribution amounts are handled. How adequate and prompt is the process to update contributions to be collected to address retroactive changes employees can make to their benefits (for example, a qualified status change such as marriage or a new child)?
- Review the overall process for collecting employee contributions. Find out what laws or regulations may be applicable to collecting contributions. Evaluate whether these laws and regulations are being followed as required and assess IBM's monitoring. Contributions may be collected via payroll deduction for active employees. Determine how contributions are collected from retired employees. Determine whether contributions were promptly collected. Identify whether contributions are taxable under the plan design, and whether the taxability rules were implemented correctly.
- For fully insured plans, trace the flow of funds from contribution determination / collection from employees through to payment of premiums to the vendor. Did both employee and IBM contributions reconcile with the premium payment amount(s)? Were payments processed correctly, and in a timely manner?

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Benefits (Medical and Ancillary)

Primary Test: Claims Processing (BN003.P)

Objective:

Determine whether benefits claims were promptly and correctly processed for eligible participants.

If claims processing is handled by a vendor, please note that it is not essential to perform IBM internal audit field work at the vendor's location. Internal audit field work performed at the vendor may require notice to be given well in advance. You may decide to select a sample and test, or you may decide to ask the IBM benefits team to provide assurance.

Risk or Exposure: Failure to promptly and correctly pay valid claims made by eligible participants could result in excess expenditures, disputes, and risk of litigation

Approach:

- Review the processes for determining whether claims are valid and correct, including claim eligibility, the service provided, and the expense covered by the benefit program. Understand how deductibles, co-payments, and co-insurance are considered when determining the amount of reimbursement for claims. For example, some plans allow for coordination of benefits between spouses, where IBM pays a percentage of an employee's claim and the employee's spouse's plan covers the remainder. Claims should be paid only up to the appropriate amount.
- How adequate and prompt is the process to incorporate retroactive changes employees can make to their benefits (for example, a qualified status change such as marriage or a new child)?
- How is IBM assured that claims are: for covered services, promptly handled, paid for the correct amount, and paid only for eligible beneficiaries (active or retired employees and their dependents)? If benefits are taxable, who pays the taxes? Test to see if taxes were paid correctly when due. If benefit payments are made via IBM Payroll, evaluate and test claims payment processing against plan design and assess execution, particularly the flow of information from Benefits to vendor to Payroll.
- Evaluate how claims are handled. Find out what laws or regulations may be applicable to claims processing, evaluate whether these are followed as required, and assess IBM's monitoring. How is IBM assured that claims are: for covered services, promptly handled, paid for the correct amount, and paid only for eligible participants?
- Test the process for handling and resolving aged claims for example, claims that are pending the receipt of required documentation from the participant. How were write-offs verified, reviewed, approved, and processed?
- Determine how overpayments are identified, reported, and handled. What process is in place to assure that overpayments will not happen, or will be promptly detected if they do happen? If overpayments do occur, how adequate is the process to recover the money? How are write-offs verified, reviewed, approved, and processed?
- Review the process for communicating and resolving appeals of denied claims. Countries may have laws or regulations requiring fairness and providing a means for appeal if claims are denied. How clear are the communications about how a claimant can file and escalate appeals of claims that have been denied? Evaluate the adequacy of aging and reporting of appeals of denied claims.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Benefits (Medical and Ancillary)

Primary Test: Benefits Funding (BN004.P)

Objective:

IBM must make funds available in a timely manner so that either premiums can be paid (if the vendor pays claims) or claims can be paid (if IBM self-insures). This means that additions and withdrawals need to be managed correctly. Determine whether contributions and premiums or claims paid were correctly recorded on IBM's ledger. Determine whether adequate funding was available when required, was reconciled, and any adjustments were correct, supported, and properly approved before ledger entries were made.

Risk or Exposure: Failure to assure adequate funding to pay claims made by eligible participants could result in dis-enrollment from benefit programs, employee dissatisfaction, disputes, incorrect or inadequate trust fund balances, and risk of litigation.

Approach:

- Countries may have laws or regulations requiring the availability and adequacy of funds to satisfy benefits obligations (liabilities, including reserves where applicable). Understand the regulatory environment and what is required. Understand the process for funding benefits, including any modifications to funding.
- Identify all the accounts involved in funding. For example, there may be one account for active employees and their eligible dependents, while there may be a different account for retired employees and their eligible dependents.
- Determine whether any premiums or claims were funded through trust accounts. If separate funding was required by laws or regulations, for example, COBRA in the US, determine whether these requirements were met. If there is a trust account, test whether payments made from the trust were approved as trustable expenses.
- Determine whether contributions collected (and/or other additions) were properly recorded on IBM's ledger. How does management ensure this? Were the additions recorded on the ledger in the correct accounting period? Were the additions recorded in the correct ledger account?
- Determine whether premiums or claim amounts paid out (and/or other withdrawals) were properly recorded on IBM's ledger. How does management ensure this? Were the withdrawals recorded on the ledger in the correct accounting period? Were the withdrawals recorded in the correct ledger account?
- Review the process and assumptions made for determining the amount of funds required and for assuring that funds were available in the correct accounts when required to pay claims. Is the process adequate? Test management's process for assuring that trust account(s) and the amounts in the trust account(s) are correct on IBM's ledger. Were additions to and withdrawals from trust account(s) processed in the correct accounting period, and to the correct ledger account?
- If claims are paid by the program administrator (PA), determine whether funds were reconciled periodically and reimbursed in a timely manner.

BENEFITS AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Benefits (Medical and Ancillary)

Primary Test: Benefits Funding (BN004.P)

(Continued)

- If any adjustments were made, review the rationale, timing, and approvals.
- Test the process for assuring that claims paid, and any tax consequences, are correctly recorded on IBM's ledger. Were the claims and any resulting taxes recorded in the correct accounting period? Were the claims, and any tax consequences, processed to the correct ledger account(s)?
- How is IBM assured that the rates calculated by the administrator of the plan are sufficient to capture the estimated number/dollar value of claims being submitted? Who is responsible for the review and approval of the plan?

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Benefits (Medical and Ancillary)

Primary Test: Reserves (BN005.P)

Objective:

Reserves are required for certain situations to ensure adequate funding is available.

Three examples are:

1. Services have been incurred but have not yet been paid, such as a doctor visit in December, with payment to provider (doctor) in January.
2. Care or treatment is involved that will occur over an extended length of time, such as long-term disability, a complex case requiring extended treatments, orthodontia, etc.
3. Trust accounts are used, which receive collected contributions that are used to pay claims.

Risk or Exposure: Failure to assure adequate reserves to pay claims made by eligible participants could result in disenrollment from benefit programs, disputes, incorrect or inadequate trust fund balances, and risk of litigation

Approach:

- Review the process for determining when and whether reserves are to be established. Understand how the amount of reserves is established. For example, what information is required from the benefits Program Administrator (PA)? Determine how reserve requirements are communicated to Accounting.
- Examine the reserves activity for the timeframe being audited. Understand how amounts were determined, reviewed, and approved for both additions to and decreases to reserves. Test whether the process was correctly executed.
- Test how management is assured that the level of reserves is appropriate.
 - How are factors such as claims experience crossing the ends of months, quarters, or years addressed?
 - How are situations identified that involve care or treatment that will occur over an extended length of time?
 - How are the dollar amounts determined for the reserves?

Select a sample of claims activity requiring reserves. Test whether the process is correctly executed.

- If any adjustments were made, review the rationale, timing, and approvals.

Examine spreadsheets used as part of process design and execution to determine whether unauthorized adjustments could be made without management awareness or approval.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other Tests: Use for All Aspects of HR Primary and Business Processes

Objective:

Acquired Employees - Post Integration: To ensure that all employees acquired through integration are accurately enrolled in IBM's benefits programs, with correct eligibility, data migration, and in compliance with contractual and regulatory requirements.

Compliance with Laws and Regulations: IBM must fully comply with applicable laws and regulations. Determine whether process design and execution comply with laws and regulations.

Data Protection: The Benefits process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process. Determine whether process design and execution protect personal information (PI) and sensitive personal information (SPI) for active and retired employees and their dependents who are eligible for benefit programs.

Risk/Exposure:

See risks noted in each test.

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other Tests: Use for All Aspects of HR Primary and Business Processes

Primary Test: Acquired Employees - Post Integration (OT001.P)

Objective: To ensure that all employees acquired through integration are accurately enrolled in IBM's benefits programs, with correct eligibility, data migration, and in compliance with contractual and regulatory requirements.

Approach:

For all cases, ask for information in the IDR on any acquisition that was fully integrated during the audit period in scope:

If there has been an acquisition(s)

- Request information on the timeline and integration status of the acquisition.
(Note: here in the US, there are going to be several acquisitions and they are going to be at various stages of integration)
- Ask for a listing of the acquired employees including IBM serial numbers and level (non-managers, managers, executives)
- Test for the following:
 - How were enrollment and eligibility verification handled? If employees (including managers and executives) were allowed to stay enrolled with the benefits offered by the acquired company, at what point would they be required to cease that enrollment and switch to benefits offered by IBM? Did this change occur when required?
 - How were contributions withheld and collected? If employees (including managers and executives) were allowed to stay enrolled with the benefits offered by the acquired company, how were contributions collected and remitted? At what point would the remittance cease - because they were required to switch to benefits offered by IBM? Did this change occur when required?

BENEFITS

AUDIT PROGRAM #40-00-00

- How was claims processing handled? If employees (including managers and executives) were allowed to stay enrolled with the benefits offered by the acquired company, how did IBM obtain assurance that claims were properly processed? At what point would the claims processing cease - because they were required to switch to benefits offered by IBM? Did this change occur when required?
- How were funds made available when required? If employees (including managers and executives) were allowed to stay enrolled with the benefits offered by the acquired company, how did IBM assure that funds were promptly made available? At what point would the funding of benefits cease - because they were required to switch to benefits offered by IBM? Did this change occur when required?
- How well did employees (including managers and executives), new to IBM because of acquisitions, follow IBM's program requirements?

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other Tests: Use for All Aspects of HR Primary and Business Processes

Primary Test: Compliance with Laws and Regulations (OT002.P)

Objective:

IBM must fully comply with applicable laws and regulations. Determine whether process design and execution comply with laws and regulations.

Risk or Exposure: Failure to comply with applicable laws and regulations could expose IBM to risk of litigation and harm IBM's image.

Approach:

Speak with IBM human resources and legal personnel to identify what laws and regulations could apply. Discuss how to apply this knowledge to the audit field work. Be prepared to review findings with legal personnel if needed.

Regulations could address topics such as:

- Data privacy and data protection
- Whether personal information and sensitive personal information can be handled by third parties, or handled by anyone outside the country
- When it is or is not appropriate to share personal information and sensitive personal information
- Requirements relevant to claims processing including timeliness of settlements and appeals
- Taxability of benefits
- Requirements relevant to recruiting, hiring, separations, resource actions, export regulations, work permits, etc.
- Retaining records to confirm process execution

During audit preparation and field work, keep this topic in mind for any scope area that is considered or is tested.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other Tests: Use for All Aspects of HR Primary and Business Processes

Primary Test: Data Protection (OT003.P)

Objective:

The Benefits process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process. Determine whether process design and execution protect personal information (PI) and sensitive personal information (SPI) for active and retired employees and their dependents who are eligible for benefit programs.

Risk or Exposure: Failure to protect PI and SPI could enable fraudulent activity, which could result in dissatisfied employees, damage to employees and to IBM's image, and expose IBM to risk of litigation.

Approach:

- Identify what benefits data is considered PI or SPI in the country being evaluated based on IBM directives and local legislation. Identify any regulations relating to data handling, such as whether PI and SPI can be handled by third parties or handled by anyone outside the country. Consider ways that PI and SPI could be compromised.
- Apply the following common data protection tests for anyone involved in performing benefits process steps. This includes IBM employees (active, on leave, separated), contractor employees working for IBM departments, and vendor firms (their employees).
 - Workplace security (controlled access, workspace, file rooms, print output rooms)
 - Access to data and applications (including granting, periodic revalidating, and revoking)
 - Separation of duties (including assessment of roles, tasks, and access to applications)
 - File transfers among IBM and vendors, including encryption and classification as IBM Confidential where required
- Spreadsheet protection
- Disaster recovery / business continuity planning. For example, if work is normally performed at IBM or vendor office facilities, but a disaster occurs and the plan calls for employees to work remotely, how secure are the means employees would have to perform their tasks at a remote location? Would unsecured telephone and internet access be used?
- Data protection terms in contracts. Review contracts with vendors or contractor employees. How is data privacy assured? Are periodic reviews, such as ISAE 3402, required by IBM? How does IBM monitor vendor protection of data? Are IBM's information technology standards in place, monitored, and enforced?

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other Tests: Use for All Aspects of HR Primary and Business Processes

Primary Test: Data Protection (OT003.P)

(Continued)

- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Vendor Management

Objective:

To determine if management has established processes and procedures to manage the scope of work assigned to Benefits vendors. Determine if the contract was established utilizing Procurement, included detailed scopes of work, change management requests, appropriate business and legal clauses, and defined vendor performance metrics. Also, determine if the contract was adequate to deliver the business objectives of a divested business.

Risk/Exposure:

Inadequate management of contractual requirements and vendor relationship could impact the continuity of service, could damage IBM's reputation, and affect IBM's profitability. Ineffective change management of contract requirements could lead to missed business objectives and additional costs. Ineffective management system for the verification of receipt of goods and services could lead to payments made for services not received.

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Vendor Management

Primary Test: Contract Management (initial contract as well as contract changes) (VM001.P)

Objective:

To determine if management has established processes and procedures to manage the scope of work assigned to Benefits vendors. Determine if the contract was established utilizing Procurement, included detailed scopes of work, change management requests, appropriate business and legal clauses, and defined vendor performance metrics. Also, determine if the contract was adequate to deliver the business objectives of a divested business.

Approach:

1. Review the process documentation developed by management that defined management's roles and responsibilities for meeting business objectives for divested operations. Verify the following:
 - a. The responsibilities between IBM Benefits and the vendors had been clearly defined in the roles and responsibilities documentation.
 - b. Key performance metrics had been established by Benefits management to monitor the vendor performance.
2. Review the divestiture contract for the following criteria:
 - a. Did the scope of work clearly define the services to be performed by the vendor? Were these requirements complete and were deliverables defined and measurable?
 - b. Was the vendor key performance metrics specified in the contract? Had management established a method for validating those services had been received and performed according to the contract?
 - c. Did management have a set management system to monitor contract deliverables?
 - d. Did the management system include oversight of operational change management elements?

BENEFITS

AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Vendor Management

Primary Test: Contract Performance Measurements (VM002.P)

Test: Contract performance measurements – SLAs and/or KPIs

Objective:

To determine if appropriate key metrics and other performance criteria and service level agreements were in place to provide management with visibility concerning the Benefits vendors' performance against the requirements specified in the contract and scope of work.

Approach:

Review if key metrics, SLAs, and other performance measurements were monitored and reported to management. Evaluate the management process for determining that results were reported and within target.

1. Did the management establish review and reporting of key metrics and SLAs including: frequency, management review method, and reporting to determine that the vendor was meeting its minimum expected service levels?
2. Did key metrics and SLAs focus on timeliness and quality?
3. Were these key metrics and SLAs included in the scope of work?
4. Did the vendors provide timely and accurate reporting of key metrics and SLAs to IBM as required in the contracts?
5. When the vendors' performance targets were not met, was this documented and were action plans developed and followed to resolve?

BENEFITS AUDIT PROGRAM #40-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Vendor Management

Primary Test: Vendor Cost (VM003.P)

Test: Vendor Cost – Invoice Validation and Payment

Objective:

Review the invoice validation process to determine that payments were for authorized services, had been delivered, were properly validated and approved before payment, cross reported where required, correctly accounted, and in compliance with contract terms and conditions.

Approach:

Request a list of invoices issued to IBM by Benefits vendors for services rendered. Test for the following:

1. Was the invoiced service authorized?
2. Was the invoiced amount according to the contract terms and conditions? Check if the price matched the committed amount per the contract.
3. Was the invoiced service delivered? Note: The proof of service is currently validated through sampling.
4. Was there duplicate payment made to the vendor?
5. Was the invoice issued within the invoice timing SLA stipulated in the vendor contract?
6. Was the invoice paid timely according to the terms of the contract?
7. If there was non-compliance to 1-5 above, was the vendor notified of the invoicing issue, and was the invoicing issue tracked and monitored to closure?
8. Review the process for requesting and receiving credits from the vendor. Assess controls to ensure that claims for penalties or deficient services were filed and resolved promptly, and that credit notes were received from the vendor promptly. Verify if there was adequate documentation explaining the credit reason.